

LAPORAN PENGUJIAN REST API CRAFTIVE DENGAN POSTMAN

Laporan ini disusun khusus untuk mendokumentasikan hasil pengujian sistem keamanan dan fungsionalitas REST API pada aplikasi **Craftive** menggunakan **Postman Desktop Client**.

1. Informasi Lingkungan Pengujian (Environment)

Sebelum memulai pengujian, variabel lingkungan diatur pada Postman untuk mempermudah eksekusi endpoint secara dinamis:

- base_url:** `http://localhost/craftive/public/api`
- jwt_token:** *(Diisi otomatis oleh skrip pengujian setelah login berhasil)*
- X-API-KEY:** `craftive-public-key-2026` (Digunakan untuk proteksi katalog publik)
- Basic Auth:** Menggunakan header otentikasi standard Base64 `email:password`

2. Contoh Uji Skenario Keamanan (Token & API Key)

A. Uji Proteksi API Key (X-API-KEY)

Sistem melindungi data katalog publik dari scraping massal menggunakan header X-API-KEY.

- Metode:** GET
- Endpoint:** `/api/catalog/products`
- Kondisi Tanpa Key:** Mengembalikan status 401 Unauthorized dengan pesan "Unauthorized. Invalid API Key".
- Kondisi Dengan Key:** Mengembalikan status 200 OK dengan daftar produk JSON.

Uji Proteksi API Key

Gambar 1: Hasil Uji Coba Penolakan Akses Tanpa API Key

B. Uji Otentikasi Token JWT (JSON Web Token)

Digunakan untuk mengamankan proses transaksi penting seperti keranjang belanja, checkout, dan pengajuan kustom kriya.

- Metode:** POST
- Endpoint:** `/api/auth/login`
- Payload Request:**

```
{
  "email": "testbuyer@craftive.id",
  "password": "password"
}
```

- Response Sukses (200 OK):**

```
{
  "message": "Login successful.",
  "data": {
    "user": {
      "id": 1,
      "name": "Testing Buyer",
      "email": "testbuyer@craftive.id",
      "role": "buyer"
    },
    "token": "eyJ0eXAiOiJKV1QiLCJhbGciOi..."
  }
}
```

- Skrip Otomatisasi Postman (Tab Tests):**

```
const response = pm.response.json();
if (response.data && response.data.token) {
  pm.environment.set("jwt_token", response.data.token);
}
```

Penerbitan Token JWT

Gambar 2: Proses Login dan Penerbitan Token JWT Sukses

C. Uji Cepat HTTP Basic Authentication

Digunakan oleh sistem eksternal atau aplikasi pihak ketiga untuk membaca profil ringkas pengguna secara efisien.

- Metode:** GET
- Endpoint:** `/api/profile/me`
- Header:** `Authorization: Basic [Base64-email:password]`
- Response Sukses (200 OK):**

```
{
  "id": 1,
  "name": "Testing Buyer",
  "email": "testbuyer@craftive.id",
  "role": "buyer",
  "phone": "081999888777",
  "address": "Jl. Keadilan No. 12, Jakarta"
}
```

Uji Basic Auth

Gambar 3: Pengambilan Profil Ringkas Menggunakan HTTP Basic Auth

3. Pengujian Fitur CRUD & Otorisasi Peran (RBAC)

Sistem memastikan bahwa pembeli (buyer) tidak dapat mengutak-atik barang milik penjual (seller), dan sebaliknya.

A. Tambah Produk Baru (CRUD Artisan/Seller)

- Metode:** POST
- Endpoint:** `/api/artisan/products`
- Header:** `Authorization: Bearer {{jwt_token}}`
- Payload Request:**

```
{
  "name": "Guci Keramik Terracotta",
  "description": "Guci keramik tanah liat premium dengan ukiran tangan khas Yogyakarta.",
  "price": 450000,
  "stock": 10,
  "category_id": 2
}
```

- Uji Penolakan (Role Buyer):** Jika diakses dengan token akun pembeli, server merespon dengan 403 Forbidden dan pesan "Forbidden. You do not have the required role."
- Uji Sukses (Role Seller):** Jika diakses dengan token pengrajin, server merespon dengan 201 Created beserta objek produk yang berhasil ditambahkan ke database.

Uji CRUD Admin

Gambar 4: Pengujian Pembatasan Hak Akses CRUD (RBAC)

4. Matriks Detail Uji Coba Endpoint REST API

Berikut adalah tabel evaluasi lengkap dari seluruh skenario pengujian REST API yang didefinisikan dalam koleksi Postman:

No	Endpoint	Metode	Proteksi Keamanan	Status Code	Hasil	Keterangan Uji
1	/api/auth/register	POST	Terbuka	201 Created	PASS	Mendaftarkan akun buyer baru secara aman.
2	/api/auth/login	POST	Terbuka	200 OK	PASS	Memverifikasi sandi dan menerbitkan token JWT.
3	/api/profile/me	GET	Basic Auth	200 OK	PASS	Menarik data profil ringkas tanpa token JWT.
4	/api/catalog/products	GET	X-API-KEY	200 OK	PASS	Mengambil katalog umum dengan key valid.
5	/api/catalog/products	GET	Tanpa Key	401 Unauth	PASS	Akses diblokir sistem karena key tidak valid/kosong.
6	/api/buyer/cart	GET	JWT Bearer	200 OK	PASS	Menampilkan item belanja milik akun pembeli terkait.
7	/api/buyer/cart	POST	JWT Bearer	201 Created	PASS	Menambahkan barang baru ke dalam keranjang.
8	/api/buyer/checkout	POST	JWT Bearer	200 OK	PASS	Mengubah keranjang menjadi pesanan & memotong stok.
9	/api/buyer/payments	POST	JWT Bearer	200 OK	PASS	Mengunggah file Base64 sebagai bukti pembayaran bank.
10	/api/buyer/custom-planer	POST	JWT Bearer	200 OK	PASS	Menghitung simulasi biaya kustom lewat Agentic AI.
11	/api/artisan/products	POST	JWT + Role Seller	201 Created	PASS	Menambah item kriya baru milik toko pengrajin.
12	/api/admin/users	GET	JWT + Role Admin	403 Forbidden	PASS	Memblokir user non-admin yang mencoba melihat data pengguna.

Laporan pengujian ini menunjukkan bahwa seluruh skema otentikasi (JWT, API Key, Basic Auth) dan pembatasan otorisasi peran (RBAC) pada platform **Craftive** telah berjalan dengan baik, stabil, dan siap untuk diintegrasikan dalam rilis produksi.